

REDES Y SEGURIDAD 2

PRÁCTICA 1.3



JOHNNY: Has jugado con firewalls. Has olido los puertos abiertos como un netrunner novato. Pero déjame decirte algo: en este laboratorio no basta con cerrar la puerta, hay que saber cuándo alguien la está forzando. Necesitas un ICE (IDS, vamos): sensores fríos, despiadados, que te detectan antes de que empieces a teclear. Hoy vas a aprender a montar ese muro invisible. Porque en la red, no gana el que dispara primero... gana el que ve venir al enemigo sin que lo sepa.

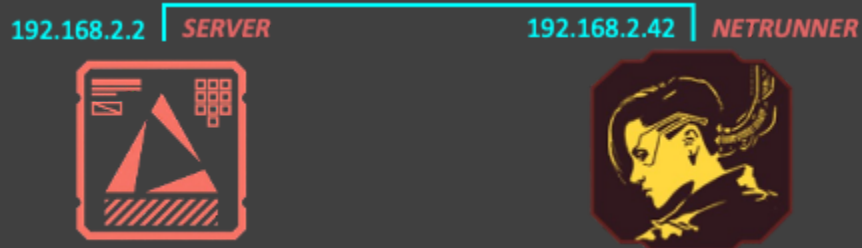
En esta práctica aprenderás a:

- Configurar el IDS/IPS **suricata**.
- Desplegar **suricata** en modo host (HIDS) y red (NIDS).



Esta práctica consta de dos escenarios diferentes.
No pases al segundo hasta no haber completado el primero.

CHAMBA: P13-ids_1



Las máquinas (**server** y **netrunner**) ya tienen su IP asignada y están listas para trabajar sobre ellas.

CONFIGURACIÓN INICIAL DE SURICATA

SERVER

Editar el fichero de configuración **/etc/default/suricata**:

- Dar valor **yes** a variable **RUN**.
- Dar valor **af-packet** a variable **LISTENMODE**.

Editar el fichero de configuración **/etc/suricata/suricata.yaml**:

- Cambiar **HOME_NET** con la IP de **server**. Ésta tiene que ir entre corchetes ([]).

SERVER

- Cambiar el valor de la variable **default-rule-path** por **/etc/suricata/rules/**.



Las líneas que comienzan con **#** están comentadas.

DETECCIÓN DE TRÁFICO ICMP

SERVER

Editar el fichero **/etc/suricata/rules/suricata.rules** (el cual no existe) y añadir la siguiente regla:

```
alert icmp any any -> $HOME_NET any (msg: "ICMP ping"; sid:1; rev:1;)
```

Arrancar **suricata** usando el comando **service**.

NETRUNNER

Hacer **ping** a **server**.

SERVER

Visualizar el contenido del fichero de alertas inmediatas (**/var/log/suricata/fast.log**) y buscar la prueba de que la regla antes introducida se ha activado.



Se pueden mostrar las últimas líneas del fichero a medida que se van generando usando el comando **tail -f**.



Se puede probar la configuración de **suricata** sin tener que arrancar el servicio, y así detectar posibles fallos.

> **suricata -c /etc/suricata/suricata.yaml -T**

DETECCIÓN DE TRÁFICO A SERVICIOS

SERVER

Arrancar los servidores IRC y SSH utilizando el comando **service**.

Editar el fichero de reglas y añadir la siguiente:

```
alert tcp any any -> $HOME_NET 6667 (msg: "Conexion IRC"; sid:2; rev:1;)
```

Reiniciar **suricata**.



El campo **sid** es el identificador de la regla, por lo que su valor nunca se debe repetir.



Se pueden añadir campos como **classtype** o **priority**, que facilitan el proceso posterior de las alertas.

Ejemplo:

... ***classtype:footprinting; priority:2;*** ...

NETRUNNER

Conectarse al servidor IRC de **server** utilizando **netcat**.

Una vez realizada la conexión, salir de la misma con **CTRL+C**, o esperar unos segundos a que el propio servidor la corte.

SERVER

Visualizar el contenido del fichero de alertas inmediatas (**/var/log/suricata/fast.log**) y buscar la prueba de que la regla antes introducida se ha activado.

INSPECCIÓN DEL CONTENIDO DE LA TRAMA

SERVER

Crear una nueva regla en la que se añada un campo llamado **Content**, tal que:

Content: "NICK";

y que alerte de la conexión de un nuevo usuario al servidor IRC.

Reiniciar **suricata**.

NETRUNNER

Conectarse al servidor IRC de **server** utilizando **netcat**.

Una vez realizada la conexión, introducir los siguientes comandos:

> **NICK johnny**

> **USER silverhand 0 * :Johnny**

> **LIST**

> **JOIN #lobby**

Y salir con **CTRL+C**.

SERVER

Visualizar el contenido del fichero de alertas inmediatas (**/var/log/suricata/fast.log**) y buscar la prueba de que la regla antes introducida se ha activado.

DETECCIÓN DE ESCANEOS DE PUERTOS

SERVER

Crear una nueva regla que, usando la etiqueta **threshold**, permite detectar un escaneo de puertos TCP SYN:

```
alert tcp any any -> $HOME_NET any (msg:"Escaneo TCP SYN detectado"; flags:S; threshold: type threshold, track by_src, count 5, seconds 10; sid:4; rev:1;)
```

Reiniciar **suricata**.

NETRUNNER

Realizar un escaneo TCP SYN con **nmap** a **server**.

SERVER

Comprobar en el fichero de alertas que se ha detectado el escaneo.



¿Qué es lo que mira exactamente **suricata** para detectarlo?

A continuación, la mecánica será la siguiente:

1. Crear una regla de **suricata** en **server** para detectar el escaneo indicado.
2. Realizar el escaneo indicado con **nmap** desde **netrunner**.
3. Verificar que se ha realizado la detección.
4. Mientras haya un tipo de escaneo por realizar, **GOTO 1**.

SERVER y NETRUNNER

Escaneos:

- TCP FIN
- TCP Xmas
- TCP NULL



Además de los apuntes y la práctica de firewalls, recuerda que siempre puedes usar **tshark** y ver así la información que buscas para identificar el escaneo.

NETRUNNER

Realizar alguno de los escaneos detectados anteriormente con **nmap**, pero ahora indicando:

- El rango de puertos sea del 20 al 25.

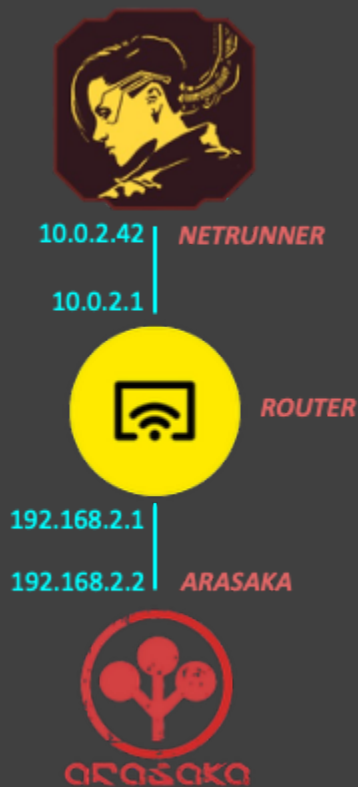
NETRUNNER

- El retardo entre pruebas sea 5 segundos.
- Que se desea obtener el mayor nivel de detalle (*verbose*).



¿Qué es lo que detecta **suricata**? ¿Por qué?

CHAMBA: P13-ids_2



La máquina **netrunner** deberá añadir con **ip route** una ruta a la red `192.168.2.0/24`, indicando la IP del **router** que está en su propia red. Por su parte, **arasaka** hará lo mismo, pero con la red `10.0.2.0/24`.

CONFIGURACIÓN DE SURICATA COMO NIDS

ROUTER

Editar el fichero de configuración **/etc/default/suricata**:

- Dar valor **yes** a variable **RUN**.
- Dar valor **af-packet** a variable **LISTENMODE**.

Editar el fichero de configuración **/etc/suricata/suricata.yaml**:

- Cambiar **HOME_NET** con la red en la que está **arasaka** (192.168.2.0/24).
- Comprobar que **EXTERNAL_NET** es todo aquello que no sea **HOME_NET**.
- Cambiar el valor de la variable **default-rule-path** por **/etc/suricata/rules/**.

Editar el fichero **/etc/suricata/rules/suricata.rules** (el cual no existe) y añadir las reglas creadas en el escenario anterior para detectar:

- Tráfico ICMP
- Escaneo de puertos TCP SYN
- Escaneo de puertos TCP FIN
- Escaneo de puertos TCP Xmas
- Escaneo de puertos TCP NULL

ROUTER

Arrancar **suricata** usando el comando **service**.

NETRUNNER

Realizar **ping** y los escaneos de puertos TCP SYN, TCP FIN, TCP Xmas y TCP NULL con **nmap** a **arasaka**.

ROUTER

Visualizar el contenido del fichero de alertas inmediatas (**/var/log/suricata/fast.log**) y comprobar que se han activado correctamente las reglas.

DETECCIÓN DE DENEGACIÓN DE SERVICIO

Se buscará detectar los intentos de denegación de servicio (DoS) mediante la inundación SYN (TCP SYN flood).

ROUTER

Crear una regla, usando de punto de partida la que detecta el escaneo TCP SYN que:

- Contenga la etiqueta **flow:to_server**.
- En la etiqueta **threshold**:
 - El tipo debe ser **both** y no **threshold**.
 - Se debe hacer seguimiento (**track**) por destino, no por origen.
 - Se deben contar **5000** paquetes en **5** segundos

Reiniciar **suricata**.

NETRUNNER

Usar el comando **hping3** para realizar un ataque de denegación de servicio del tipo TCP SYN Flood:

- Máquina objetivo: **arasaka**
- Servicio objetivo: servidor web
- Modalidad: envío de paquetes lo más rápido posible (**flood**)
- Extra: IP aleatoria

ROUTER

Visualizar el contenido del fichero de alertas inmediatas (**/var/log/suricata/fast.log**) y comprobar que se han activado correctamente las reglas.



¿Por qué en la nueva regla se usa la etiqueta **track by_dst** y no **by_src**?

SURICATA COMO IPS

ROUTER

Editar **/etc/default/suricata** para indicar que el **LISTENMODE** es ahora **nfqueue**.

Reiniciar **suricata**.

Ahora, para que **suricata** pueda procesar el tráfico, es necesario redirigirlo desde el firewall (**iptables**).

Como se desea procesar todo el tráfico que pase por **router**, bastará con ejecutar:

> iptables -I FORWARD -j NFQUEUE

Verificar con **iptables -L** que se ha realizado la redirección.

NETRUNNER

Realizar **ping** a **arasaka**, así como cualquiera de los escaneos de puertos anteriormente detectados y el ataque de denegación de servicio.

ROUTER

Visualizar el contenido del fichero de alertas inmediatas (**/var/log/suricata/fast.log**) y comprobar que se han activado correctamente las reglas.

Cambiar en el fichero de reglas la acción **alert** en la detección del tráfico ICMP por **drop**.

Reiniciar **suricata**.

NETRUNNER

Hacer **ping** a **arasaka**.



¿Se consigue realizar el ping? ¿Por qué?

ROUTER

Recuperar la regla elaborada en el anterior escenario que detectaba un nuevo usuario conectado al servidor IRC.

Ahora la acción debe ser **drop** y la cadena con la que debe activarse es **"NICK johnny"**.

Reiniciar **suricata**.

NETRUNNER

Realizar el mismo proceso de conexión al servidor IRC de **arasaka** que se realizó en el anterior escenario.



¿Qué diferencia un IPS de un IDS?

_ EOL



¡Platinéatelo! Cambia a **drop** la acción **alert** del resto de reglas relativas a escaneos de puertos en el segundo escenario, y comprueba qué pasa con los mismos (es recomendable usar la opción **-vv** con **nmap**).



¡Un poco de orden! Usando "**classtype:**", organiza las reglas creadas en la práctica.